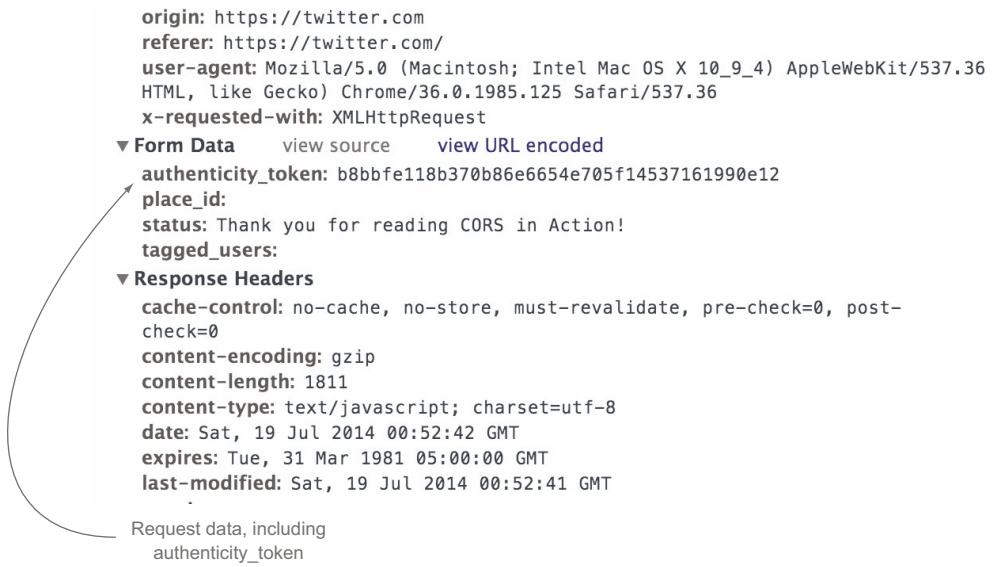


Figure C.2 Sending a new tweet request to Twitter. The `authenticity_token` guards against CSRF.

`authenticity_token` are sent to Twitter's servers. Finally, Twitter's servers compare the `authenticity_token` against the expected value. If they match, the new tweet is created; otherwise, the request is rejected.

CSRF protection works because it introduces an "active" form of protection (the CSRF token) to a "passive" form of protection (the cookie). By passive, I mean that

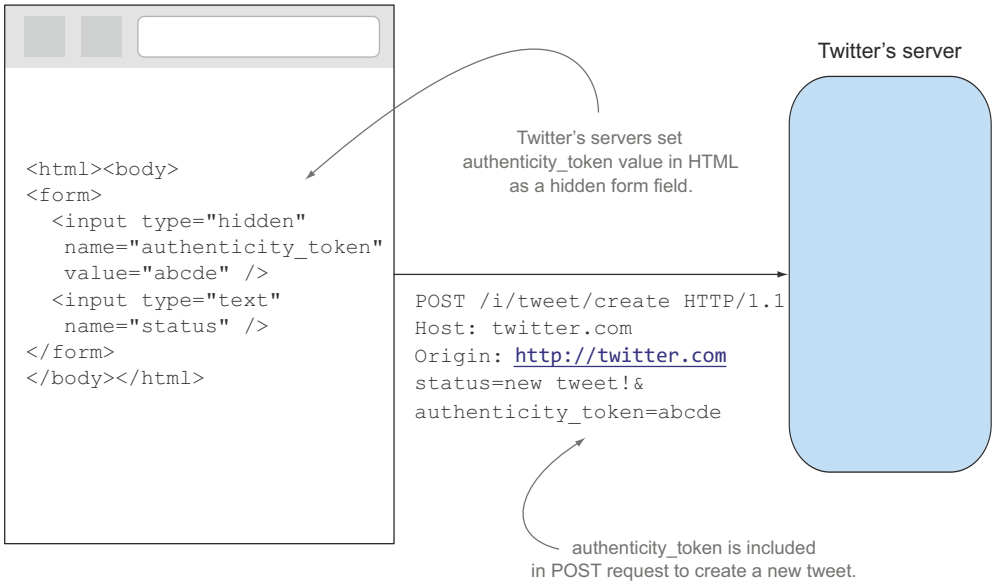


Figure C.3 How Twitter uses the `authenticity_token` field to guard against CSRF